



SCHOOL HOMEWORK - 2024

CLASS: INDUSTRIAL CONTROL SYSTEMS SECURITY

SUBJECT: STATIC MALWARE ANALYSIS & MALICIOUS PDFs —
MALWARE ANALYSIS IN CUCKOO SANDBOX — THREAT DETECTION WITH
IOC & YARA RULES — FORENSIC WITH REDLINE

FRÉDÉRIC PERRON



Table of Contents

Exercise 1 – Malicious PDF & Static Malware Analysis	1
Exercise 2 – Malware Analysis in a Sandbox (Cuckoo).....	6
Exercise 3 – Threat Detection with IOC & YARA rules	16
Exercise 4 – Forensic Analysis with Redline.....	22

Guideline

- All answers must be documented and supported with screenshots. Even if the answer is correct, if it is not documented, **your grade will be 0.**
- You must demonstrate analysis and research in the answers you provide.
- Please submit your assignments as PDF or DOC files and present your answers under the questions below by copying them exactly as written, including their question numbers.

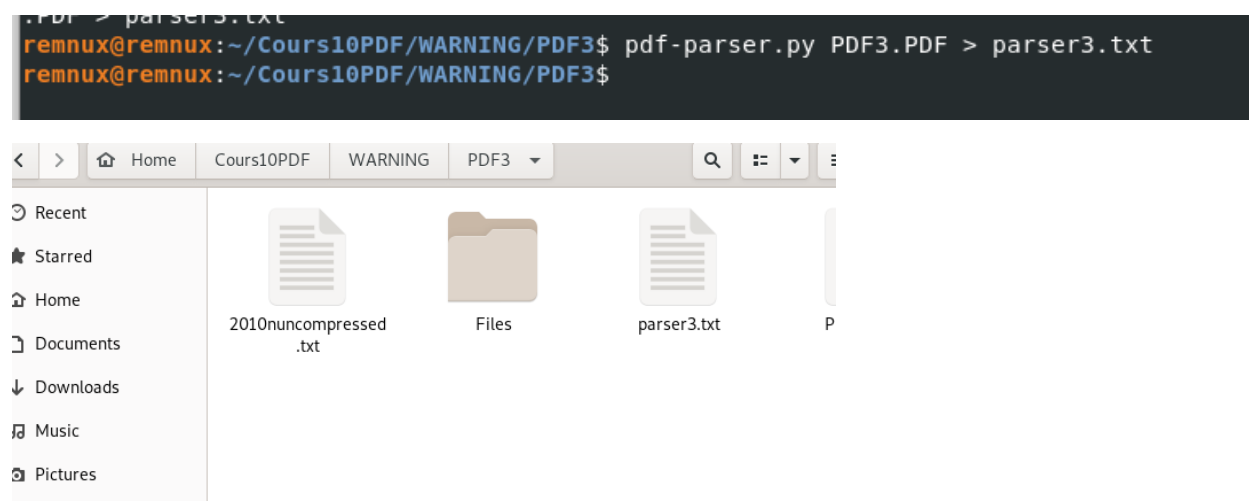
Exercise 1 – Malicious PDF & Static Malware Analysis (20p)

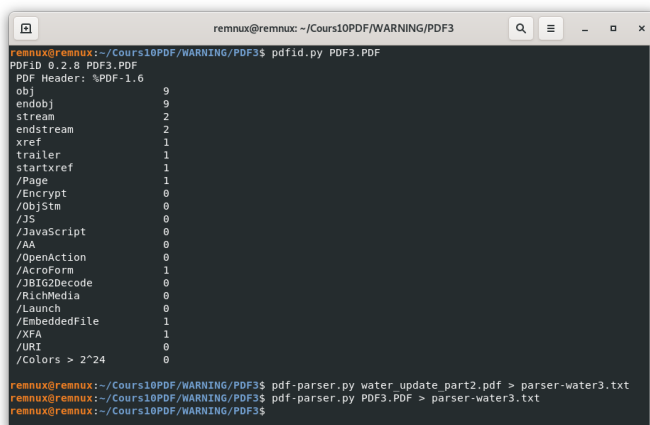
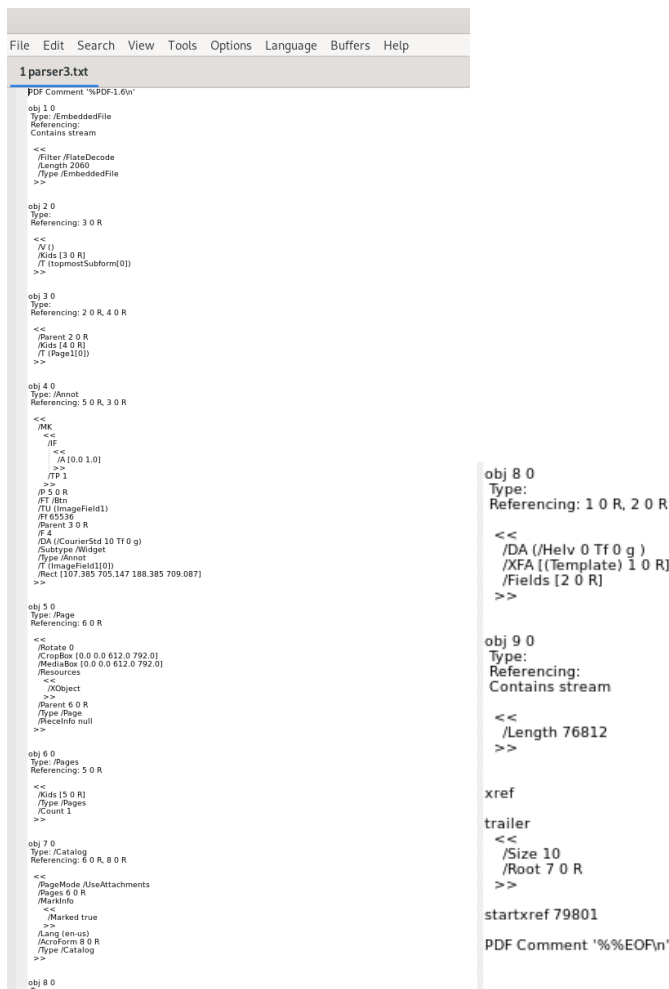
En utilisant les instructions du **laboratoire 1 - cours 10**, faites une analyse des PDF3 et PDF4, disponibles dans le laboratoire du cours 10

Using the instructions from Lab 1 – Course 10, analyze PDF3 and PDF4, available in the Course 10 lab.

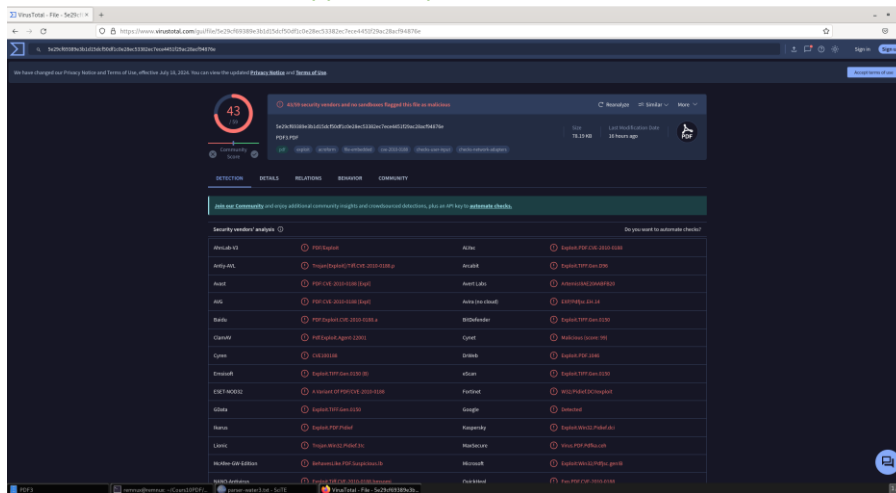
We begin with file PDF3, which is *Research Paper on Nuclear Posture Review 2010.PDF*, renamed to **PDF3** to make it easier to handle in the command line. The same was done for the file in the PDF4 folder, renamed to **PDF4**.

We start with **PDF3** and run the command from the lab using pdf-parser.



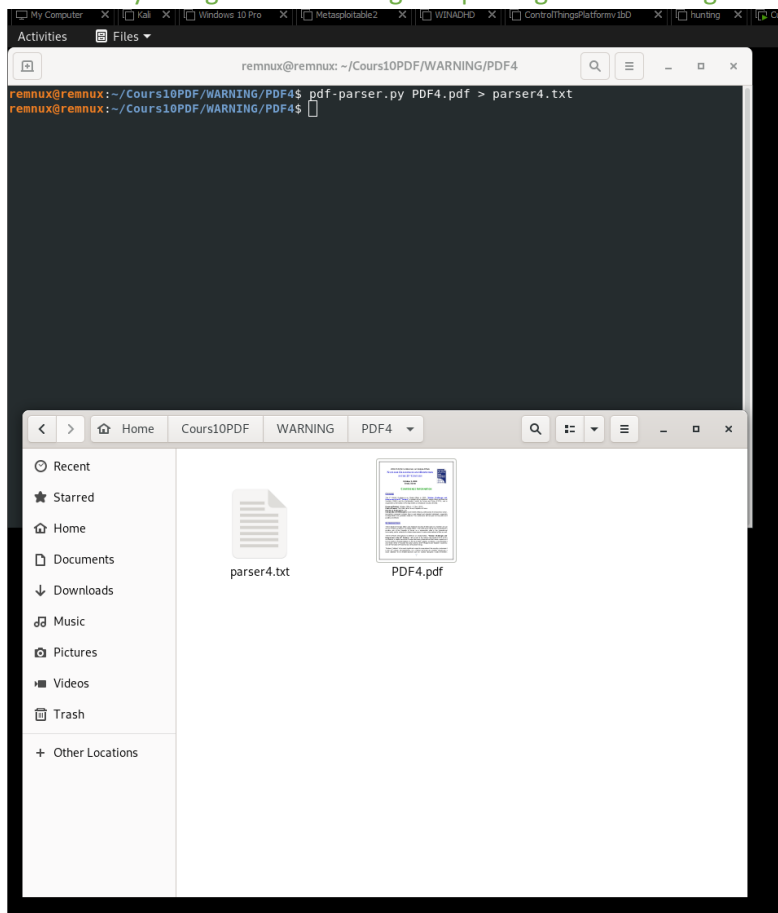


This completes the basic analysis for the lab, as there is no JavaScript code present. We can also use VirusTotal for PDFs that appear suspicious.



Now for PDF4.

We start by doing the same thing and parsing the PDF using the .py command.



By opening the parser4.txt file, we can observe that in the trailer there is already a %%EOF comment, which is normally expected at the end of the file. However, this file contains multiple instances of it, which could be considered suspicious according to the lab documentation. There are also several

```
Activities ScITE Text Editor
File Edit Search View Tools Options Language Buffers Help

1 parser4.txt

PDF Comment '%PDF-1.6)'
PDF Comment '%\xe2\xe3\xcf\xbd3'\n'

obj 387 0
Type:
Referencing:

<<
/L linearized 1
/L 374508
/O 395
/E 105533
/N 5
/T 366704
/H [ 1236 405]
>>

xref

trailer
<<
/Size 432
/Prev 366692
/XRefStm 1641
/Root 389 0 R
/Encrypt 388 0 R
/Info 61 0 R
/ID [ <531062B76A138B3DDC1D1C601E8D8CE5> <95A231D8AC9A0046ABC9FE72D7E8644> ]
>>

startxref 0

PDF Comment '%EOF'\n'
obj 430 0
Type:
Referencing:
Contains stream

<<
/Length 311
/C 344
/Filter /flateDecode
```

And indeed, this file does contain JavaScript.

```
remnux@remnux: ~/Cours10PDF/WARNING/PDF4$
remnux@remnux: ~/Cours10PDF/WARNING/PDF4$ pdf-parser.py PDF4.pdf > parser4.txt
remnux@remnux: ~/Cours10PDF/WARNING/PDF4$ pdfid.py PDF4.pdf
PDFiD 0.2.8 PDF4.pdf
PDF Header: %PDF-1.6
obj 106
endobj 106
stream 52
endstream 52
xref 2
trailer 2
startxref 2
/Page 5
/Encrypt 2
/ObjStm 4
/JS 1
/JavaScript 2
/AA 0
/OpenAction 0
/AcroForm 0
/JBIG2Decode 0
/RichMedia 0
/Launch 0
/EmbeddedFile 0
/XFA 0
/URI 0
/Colors > 2^24 0
remnux@remnux: ~/Cours10PDF/WARNING/PDF4$
```

So all that remains is to execute the commands to extract the JavaScript. *See final images below.*

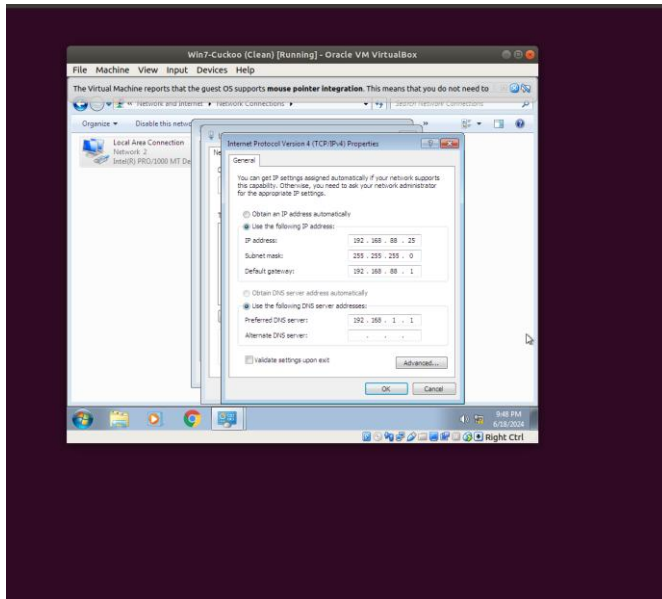
[illegible]

Exercise 2 – Malware Analysis in a Sandbox (Cuckoo)

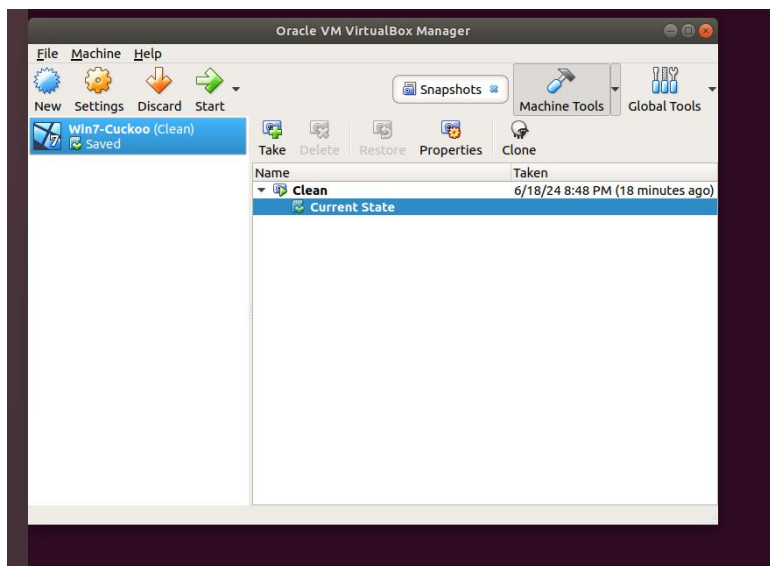
Using the **Course 10 lab (Cuckoo lab)**:

- a) Create a Cuckoo sandbox (15p)

We begin by changing the IP addresses of our Win7-Cuckoo VM to those specified in the lab.



We then take a snapshot named **Clean**.



Next, we modify the virtualbox.conf and cuckoo.conf files.


```
cuckoo@ubuntu02: ~
File Edit View Search Terminal Help
GNU nano 2.9.3 /home/cuckoo/.cuckoo/conf/cuckoo.conf Modified

# Cuckoo is capable of sending "developer feedback" to the developers so that
# they can more easily improve the project. This functionality also allows the
# user to quickly request new features, report bugs, and get in touch with
# support in general, etc.
enabled = no
name =
company =
email =

[resultserver]
# The Result Server is used to receive in real time the behavioral logs
# produced by the analyzer.
# Specify the IP address of the host. The analysis machines should be able
# to contact the host through such address, so make sure it's valid.
# NOTE: if you set resultserver IP to 0.0.0.0 you have to set the option
# 'resultserver ip' for all your virtual machines in machinery configuration.
ip = 192.168.88.1

# Specify a port number to bind the result server on.
```

```
[remotecontrol]
# Enable for remote control
enabled = yes
```

```
cuckoo@ubuntu02: ~
File Edit View Search Terminal Help
GNU nano 2.9.3 /home/cuckoo/.cuckoo/conf/virtualmachines.conf Modified

# Virtualbox will bind the VRDP interface to the first
# controlports = 5000-5050

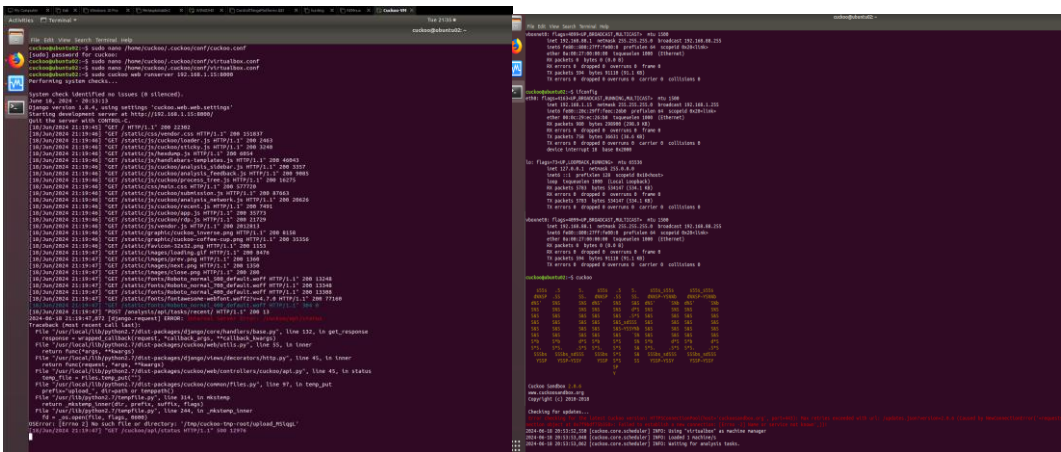
[cuckoo1]
# Specify the label name of the current machine as specified in the
# VirtualBox configuration.
label = Win7-Cuckoo

# Specify the operating system platform used by current machine.
# [windows/darwin/linux].
platform = windows

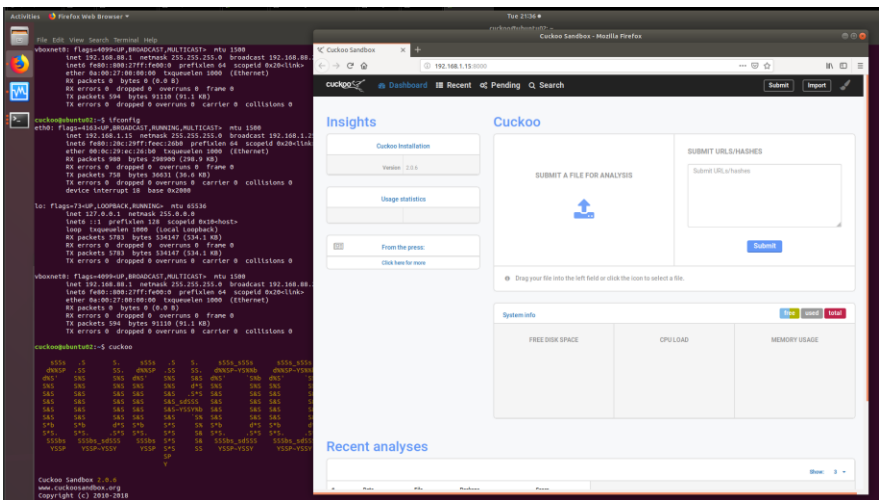
# Specify the IP address of the current virtual machine. The IP address
# IP address is valid and that the host machine is able to reach it.
# the analysis will fail.
ip = 192.168.88.25

# (Optional) Specify the snapshot name to use. If you don't specify a
# snapshot name, the default snapshot will be used.
```

After that, we can verify in the browser that the sandbox is working properly, even while still using the static address **192.168.1.15**.

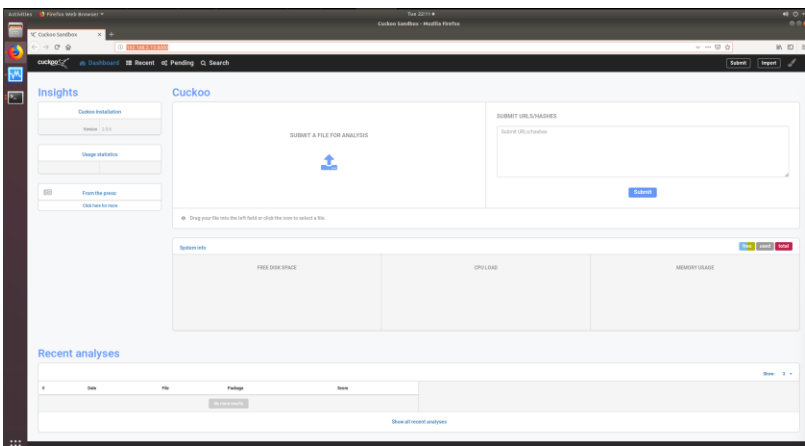


Now, when navigating to **192.168.1.15:8000** in the browser, we are prompted with the web interface of Cuckoo Sandbox. *See image below*



Next, we need to ensure that other VMs can communicate and access this same interface. To do this, we modify the static IP address in `/etc/network/interfaces`.

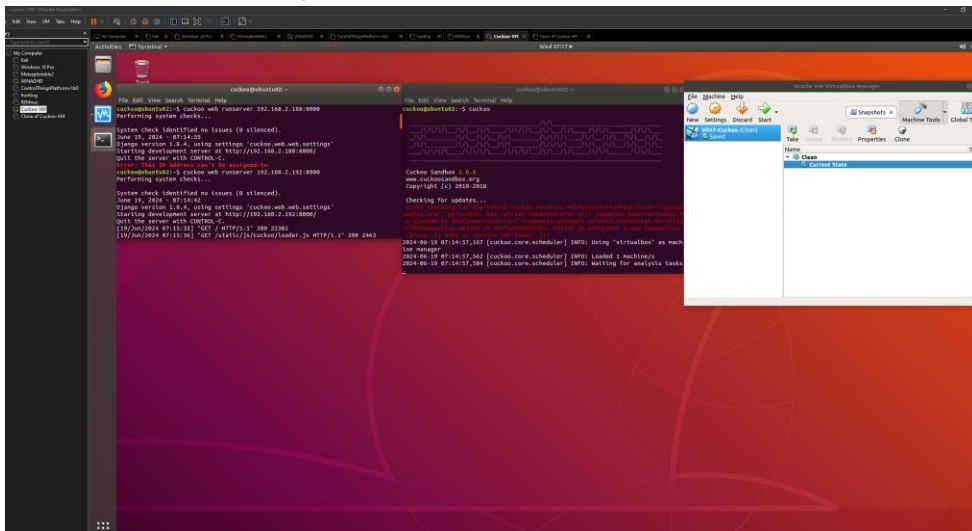
Here is the new interface after changing the IP address to **192.168.2.15**.



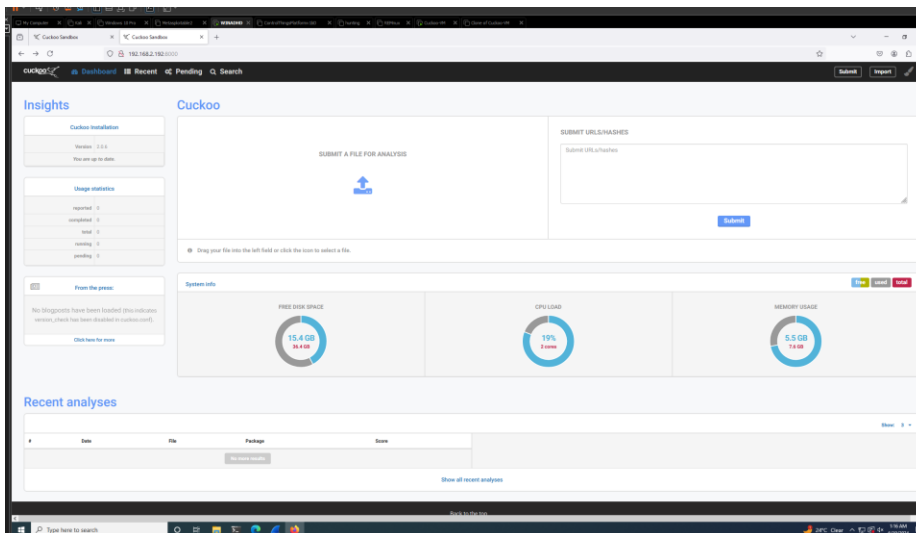
Finally, we simply go to the ADHVD VM and access the Cuckoo web interface from the server we created on the Cuckoo VM.

Had to use a previous snapshot of my VM hence the new IP address

Here is my Cuckoo terminal showing the sandbox restarting with the new IP address, along with another screenshot of my WINADHD VM inside the sandbox accessed via the web browser:



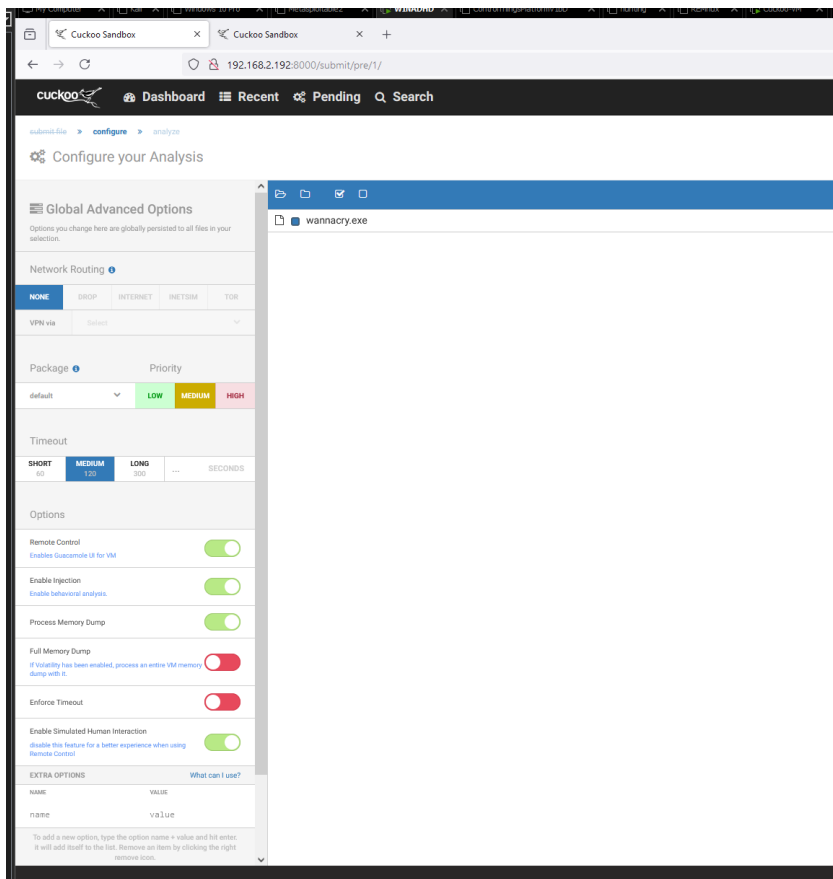
And the WINADHD VM in the web interface:



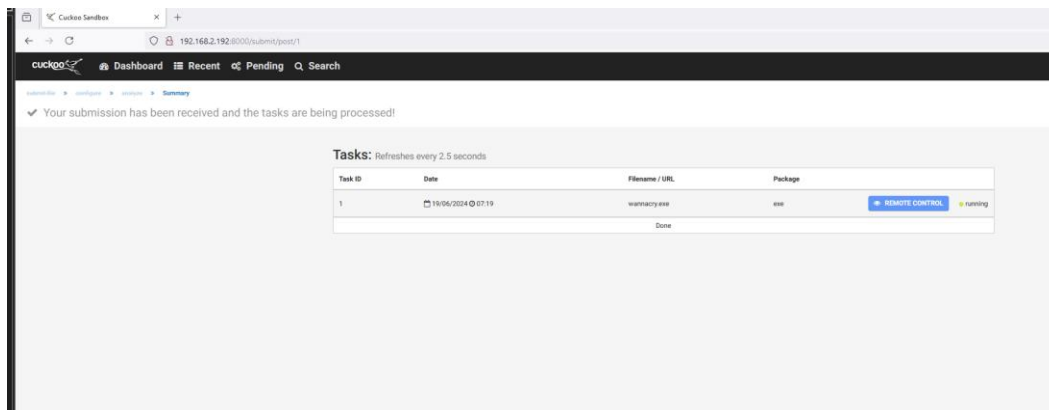
b) Similar to the lab exercise, analyze the malware **WannaCry.exe** (5p)

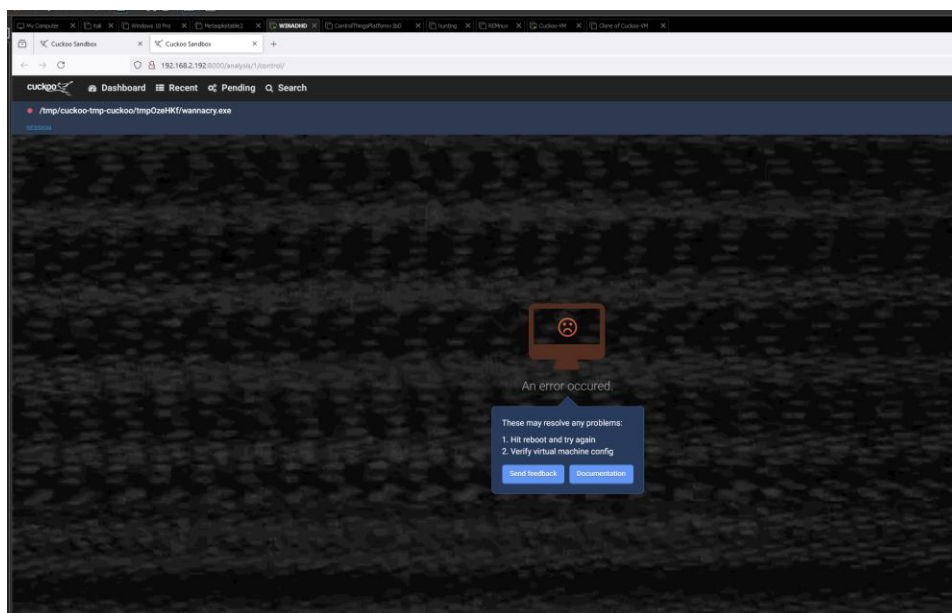
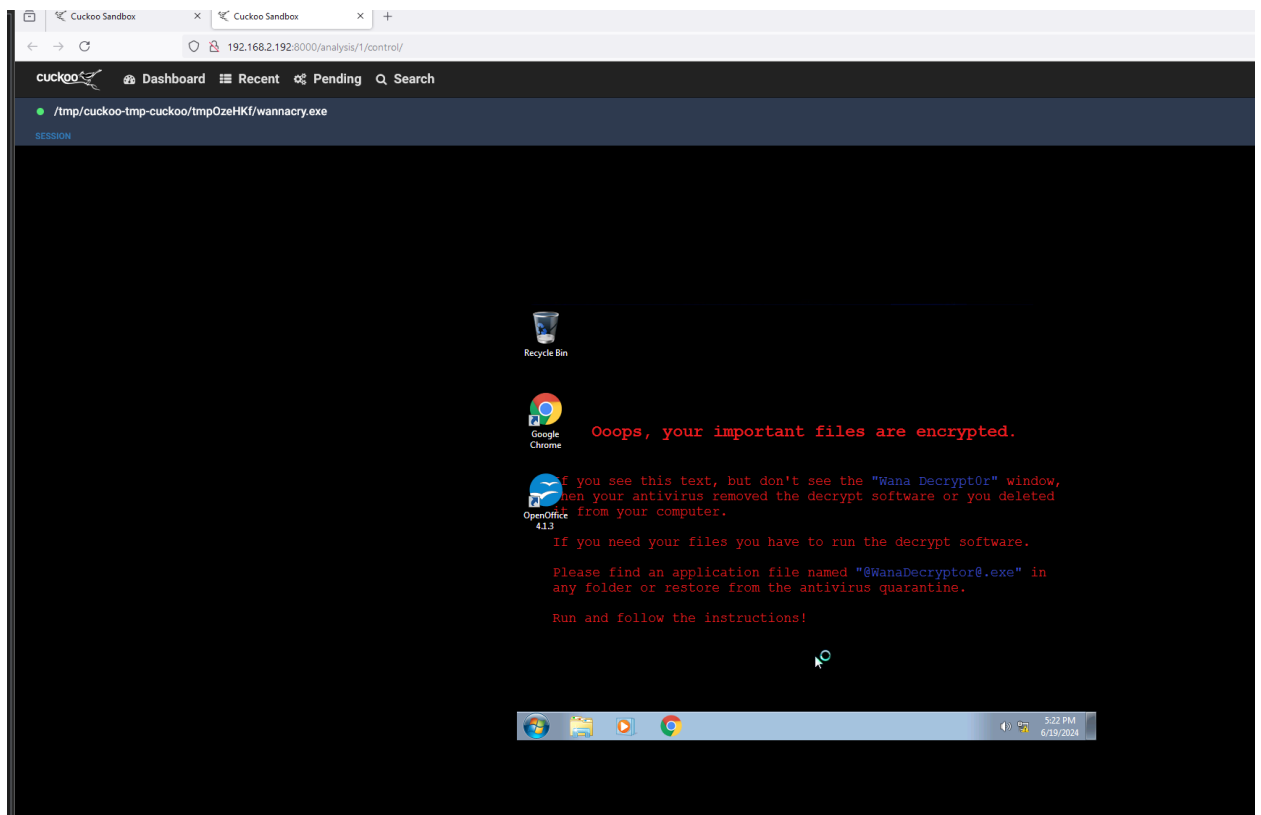
We load the file *wannacry.exe* into the sandbox and enable the **remote control** option.

Here is the initial result:

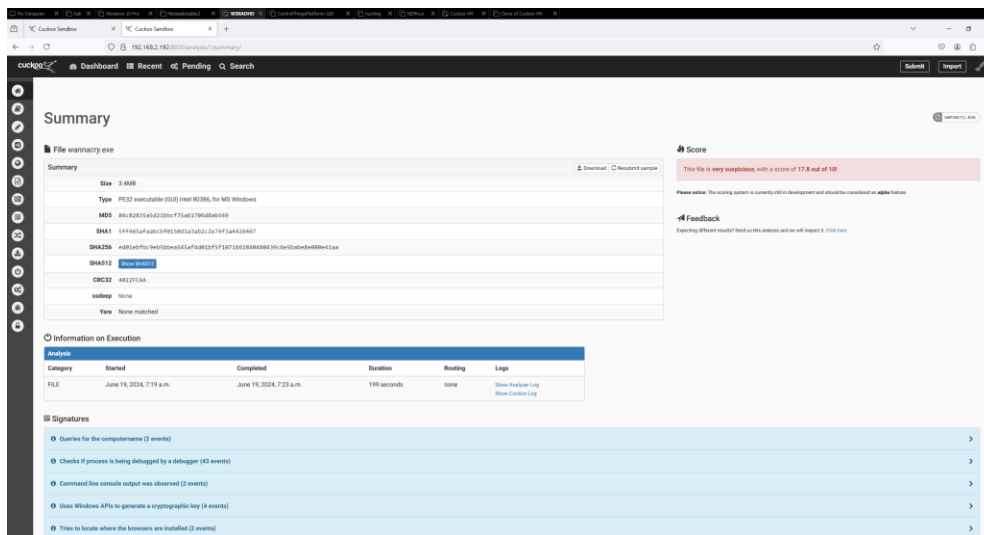


We then click on **remote control**, which opens the simulator where the malware executes.



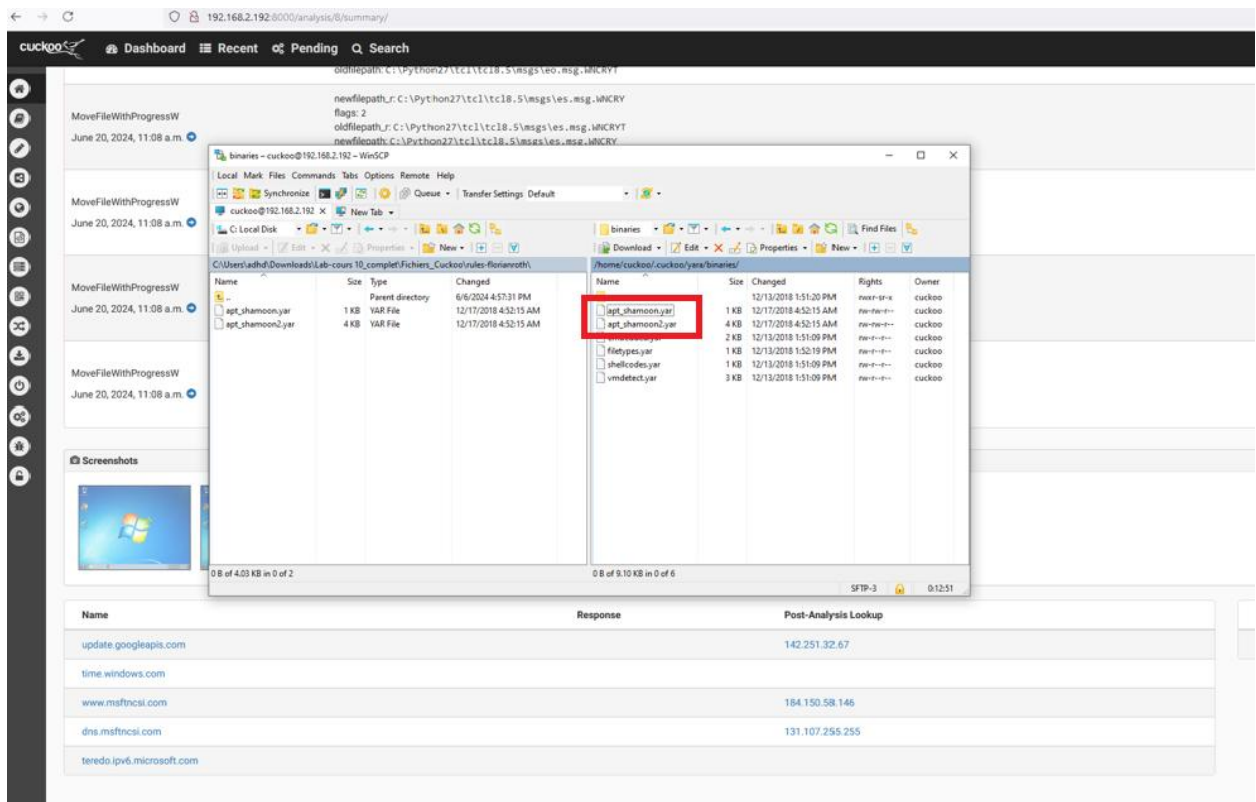


We do "Show Report" and here's what we get:



c) Similar to the lab exercise, analyze the **Shamoon** malware, including the YARA rule (5p)

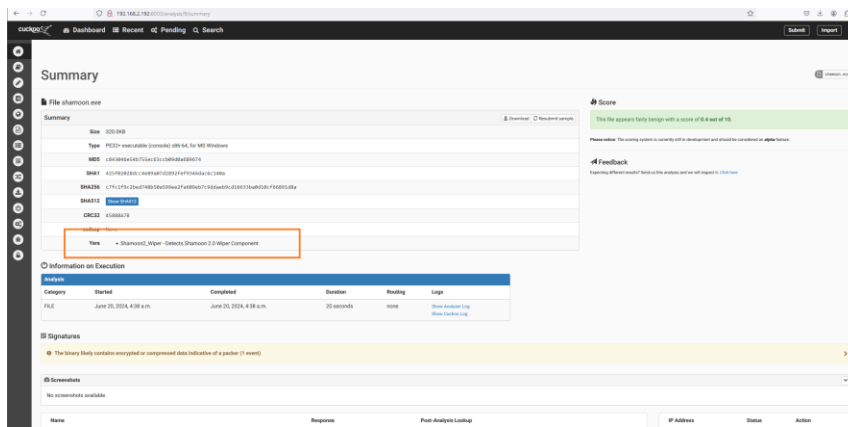
We begin by downloading WinSCP and connecting remotely using the account and IP address of our Cuckoo VM. Then, we transfer the files into the Cuckoo directory as indicated in the lab.



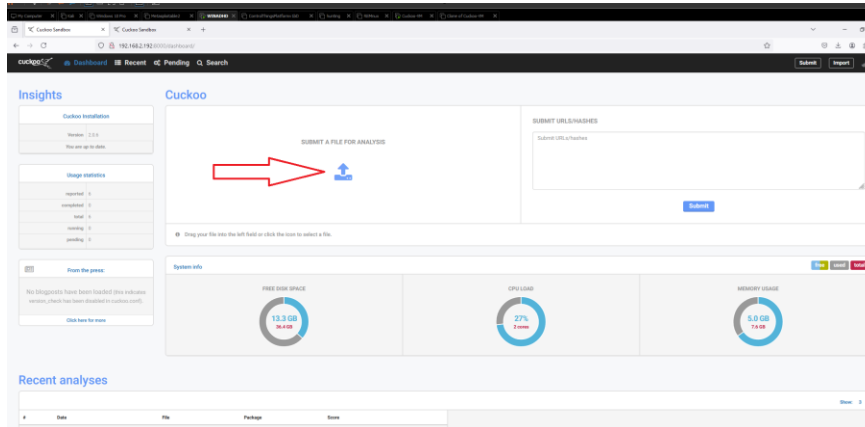
Next, we restart the Cuckoo server that we created on the VM.

We run the malware again, and we can observe that the score is relatively low compared to the previous analysis.

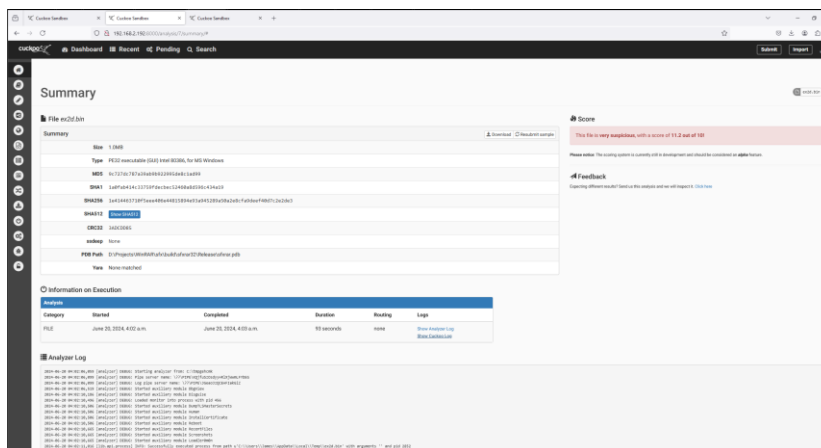
Why? Because with this rule, it is not suitable for proper sandbox operations. However, we can still observe in the summary view that YARA produced a hit. See image below.



d) Analyze the file 2d.bin in the Cuckoo sandbox. Document your findings. (5p)



We upload the file **ex2d.bin**, wait approximately one minute, and obtain the results. Here is what we observe.



By checking the provided VirusTotal and GitHub links, we can quickly determine that this is a Trojan known as LokiBot, which is classified as a Trojan (often associated with credential theft and sometimes ransomware-like behavior).

e) Analyze the file 2e.bin in the Cuckoo sandbox. Document your findings. What message is displayed in Windows 7 (via remote control) while the virus is executing? (5p)

Black Kingdom RansmWere

```
*****
| We Are Back      ?
*****

We hacked your (( Network )), and now all files, documents, images,
databases and other important data are safely encrypted using the strongest algorithms ever.
You cannot access any of your files or services .
But do not worry. You can restore everthing and get back business very soon ( depends on your actions )

before I tell how you can restore your data, you have to know certain things :

We have downloaded most of your data ( especially important data ) , and if you don't  contact us within

To see what happens to those who didn't contact us, just google : (  Blackkingdom Ransomware  )

*****
| What  guarantees      ?
*****

We understand your stress and anxiety. So you have a free opportunity to test our service by instantly d
just send the files you want to decrypt to ( ***** )

*****
| How to contact us and recover all of your files ?
*****

The only way to recover your files and protect from data leaks, is to purchase a unique private key for :

[ + ] Instructions:

1- Send the decrypt_file.txt file to the following email ==> *****

2- send the following amount of US dollars ( 10,000 ) worth of Bitcoin to this address :
[ ***** ]

3- confirm your payment by sending the transfer url to our email address

4- After you submit the payment, the data will be removed from our servers, and the decoder will be given
so that you can recover all your files.

=== Note ===

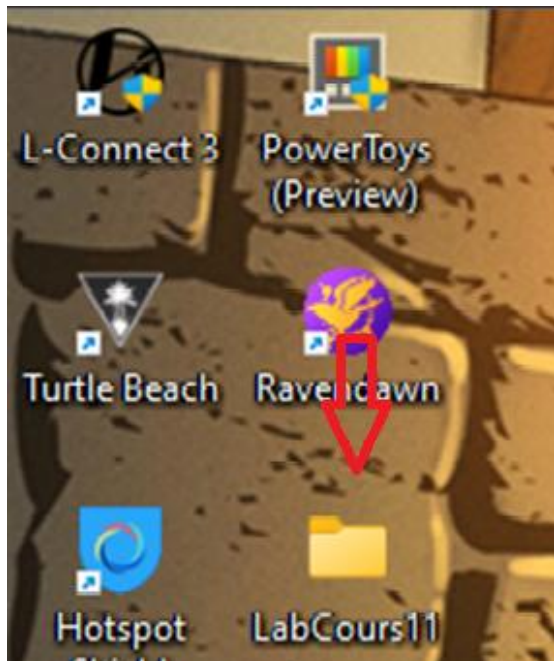
Dear system administrators, do not think you can handle it on your own. Notify your supervisors as soon .
By hiding the truth and not communicating with us, what happened will be published on social media and y

Your ID ==>
*****
```

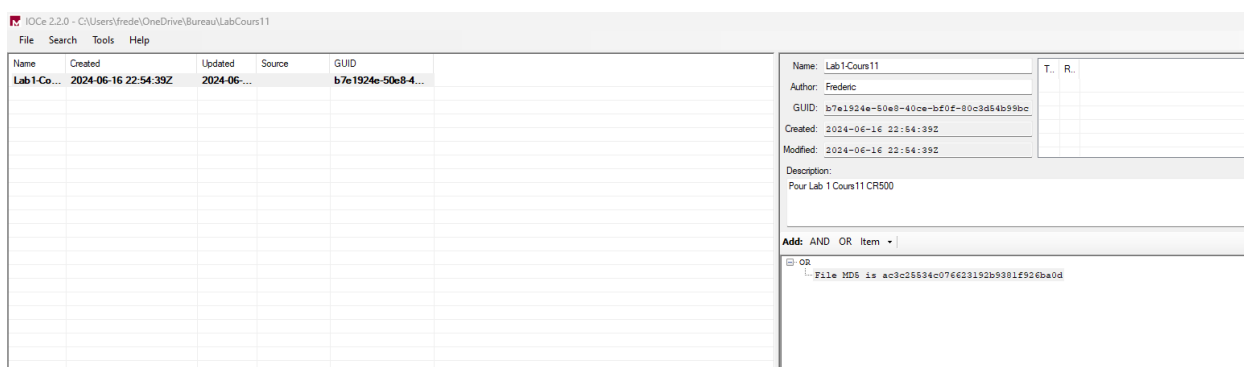
Exercise 3 – Threat Detection with IOC & YARA rules

Execute and document the **Course 11 labs**.

We begin with **Lab 1 (IOCs in action)** and create a file named **Cours11Lab** on our Desktop.



Next, following Lab 1 – Course 11, we open IOC Editor, create a new indicator, and fill in the metadata for the IOC as shown in the lab.



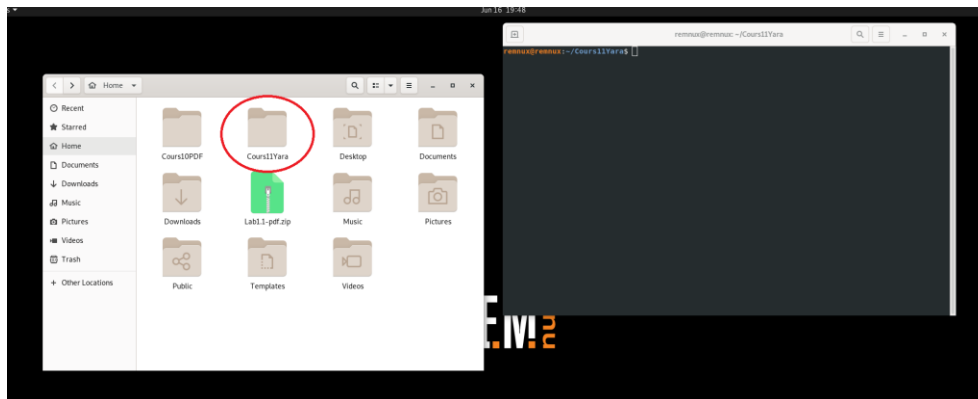
We then add the .exe processes, and our file is saved in the folder we created, **LabCours11**.

It is important not only to know that an IOC matches, but also why it matches, and whether it accurately reflects malicious activity in that specific environment. Once properly validated with minimal false positives, IOCs become one of the fastest ways to assess an organization and determine the scope of a threat.

Feedback to those creating and sharing IOCs is critical. Teams often fail to communicate their needs and challenges effectively. Providing feedback to threat intelligence producers helps improve IOC quality and ensures they better align with operational requirements.

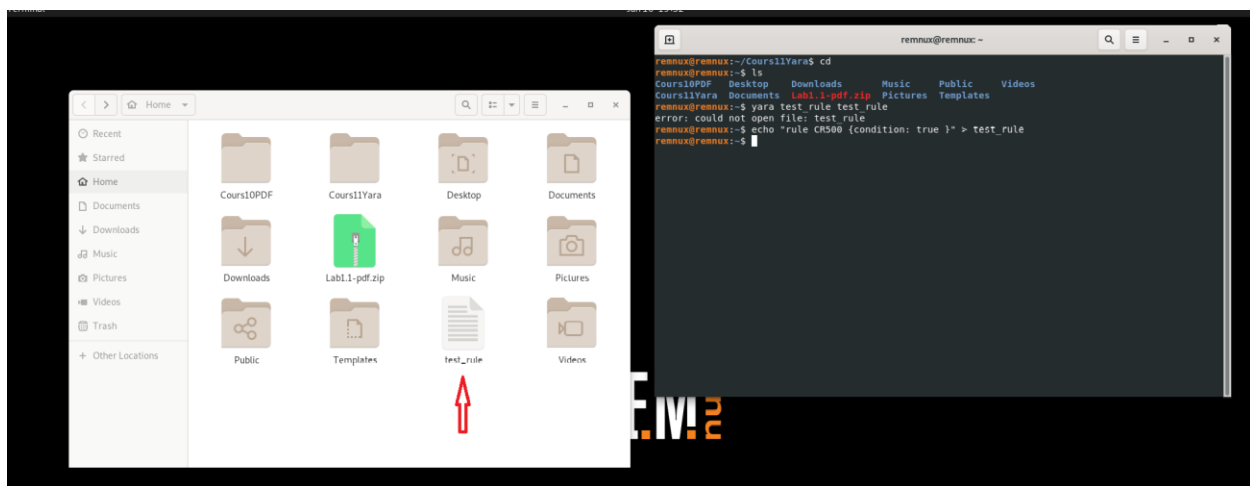
Now, Lab 2 – Yara

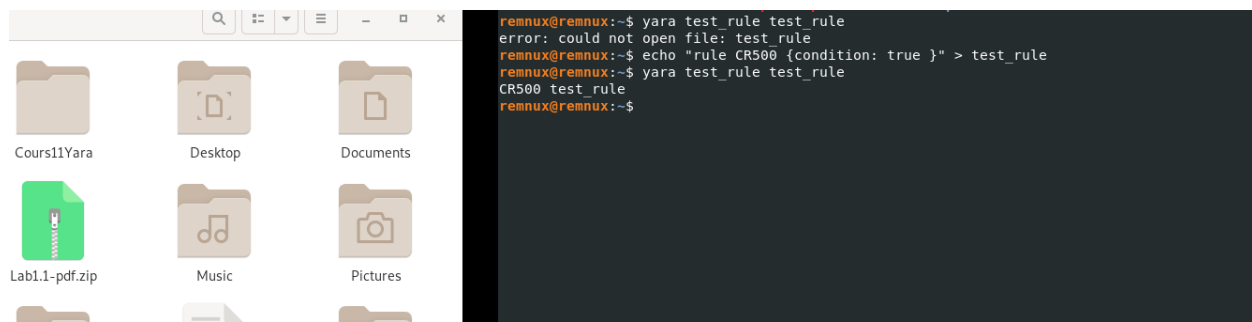
We begin by unzipping the **Cours11Yara** file so that we have a single folder containing the two memory dump files.



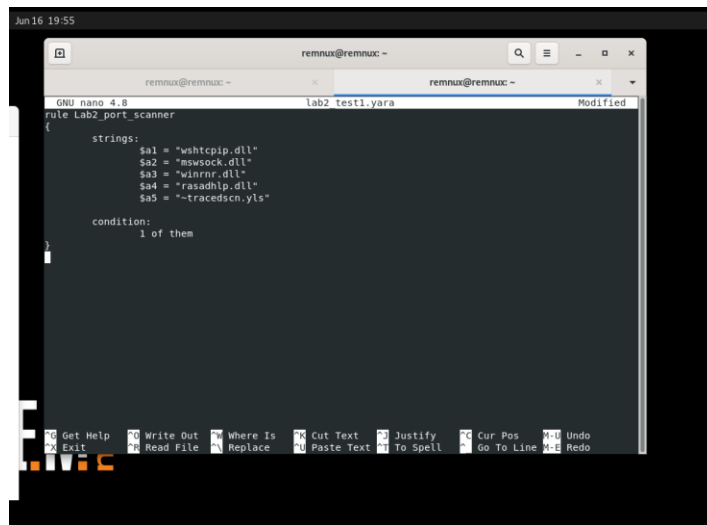
We execute the command: **echo "rule CR500 {condition: true}" > test_rule**

Then we test the rule against itself using: **yara test_rule test_rule**

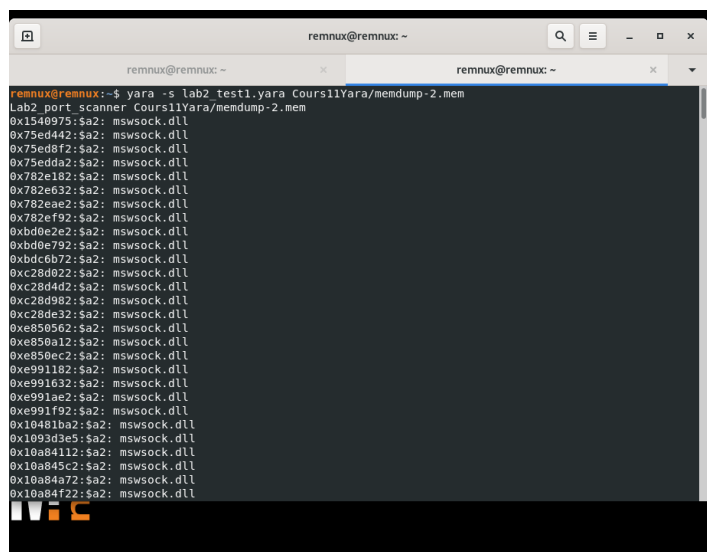




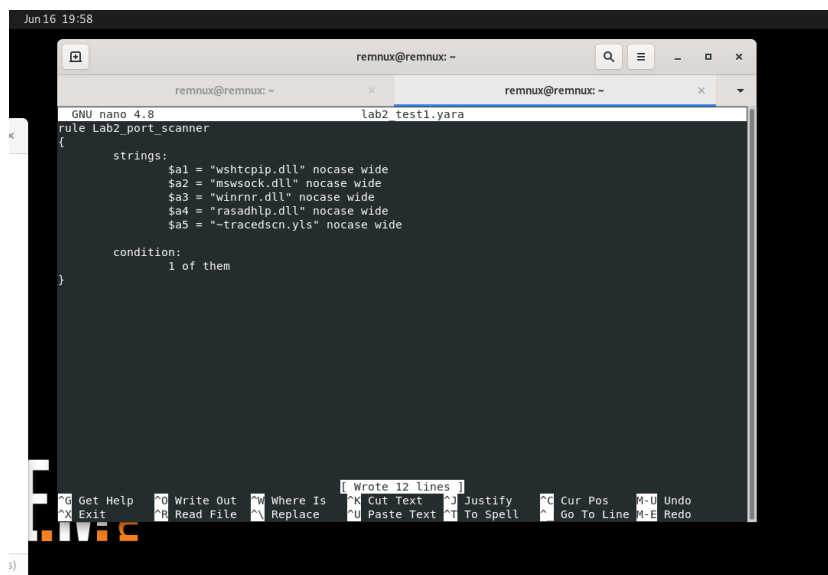
We now insert the indicators into the YARA rule as shown in the lab. See the image below for the rule in the text editor.



We then execute the rule on one of the memory images.



Next, we add nocase and wide after each string, as shown below:



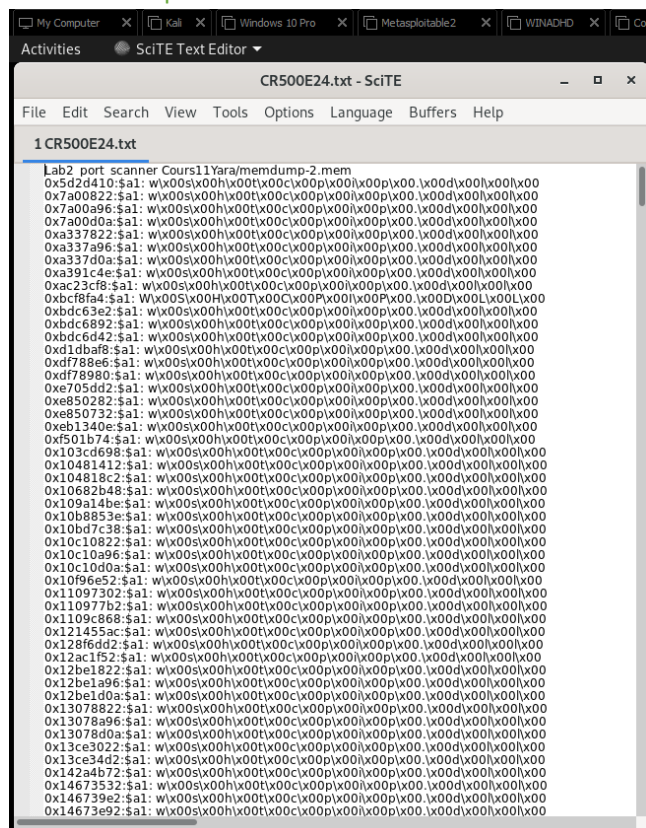
We save and exit the editor using **CTRL+O** and **CTRL+X**.

This time, we expect significantly more results, so we redirect the output to a text file for easier analysis.

We run the following command:

yara -s lab2_test1.yara Cours11Yara/memdump-2.mem > CR500E24.txt

We are then presented with the results in the text file:



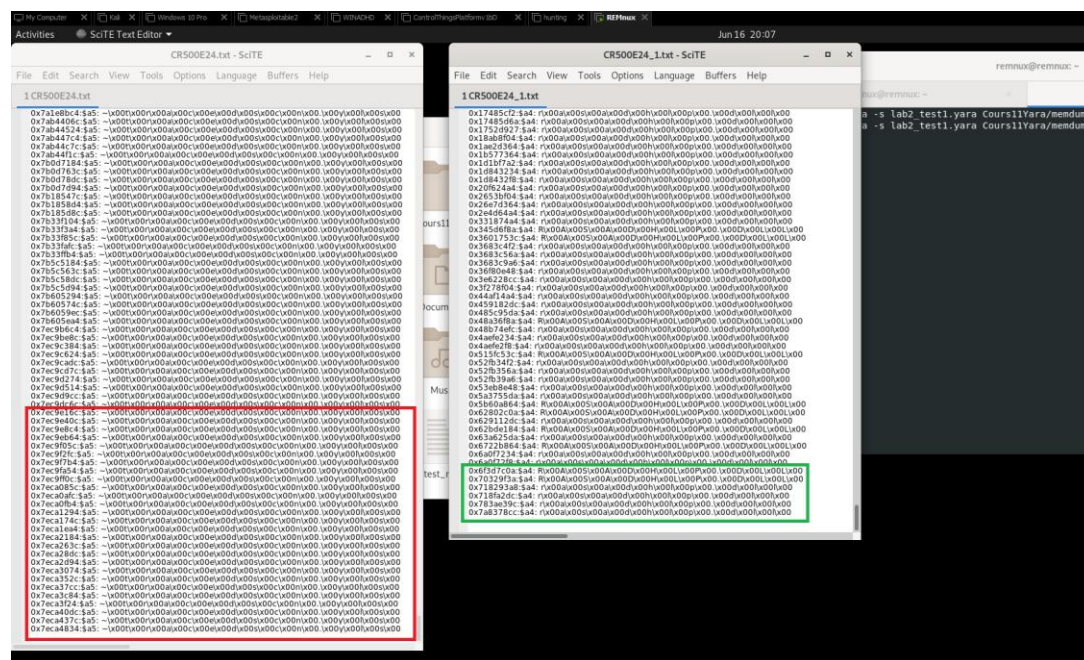
We now have hits for each string. The results appear in hexadecimal due to the **wide** option, since the strings are no longer simple ASCII. However, both the **wide** and **nocase** options allowed us to identify string instances that would not have been detected otherwise.

It is important to validate the YARA rule against a known-good image to eliminate strings that generate high false positives in the IOC.

We execute the **lab2_test1.yara** rule on the baseline memory image using the following command:

yara -s lab2_test1.yara Cours11Yara/memdump-1.mem > CR500E24_1.txt

We now have two output files that we can compare. As in the lab, we obtain consistent results:



If more information is needed to write more advanced rules, you can consult the YARA documentation below :

<https://yara.readthedocs.io/en/stable/writingrules.html>

Exercise 4 – Forensic Analysis with Redline (25p)

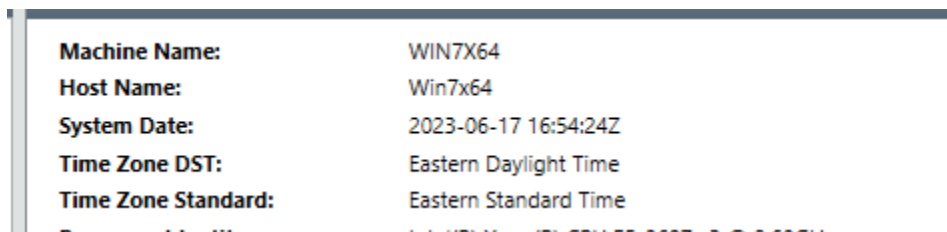
Using this redline capture:

[https://drive.google.com/file/d/1HZdfjkdf&&/\\$/&*/\\$/&**RlxqSihDir5C49NwPAF/view?usp=sharing](https://drive.google.com/file/d/1HZdfjkdf&&/$/&*/$/&**RlxqSihDir5C49NwPAF/view?usp=sharing)

(password) answer the questions (similar to Course 9 lab) :

- a) What are the name, operating system, logged-on user, and IP address of the victim system? (5p)

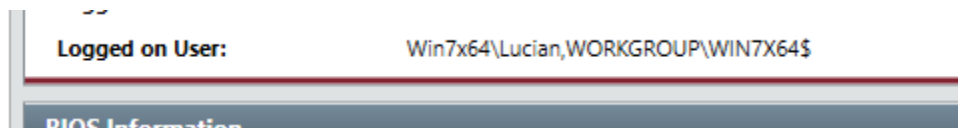
Name: **WIN7X64**



OS: **Windows 7 Professional 7600**



logged on user: **Win7x64\Lucian,WORKGROUP\WIN7X64\$**



IP address: **192.168.1.208**



- b) During incident response, you identify a machine with IP address 192.168.1.105.
- a. By examining services, open ports, etc., can you identify a connection, and if so, is it suspicious? (5p)

Yes, we can observe a connection from an HTTP server on port 8000 (basic HTTP server). A file such as **trojan.exe** is clearly suspicious and should be investigated/responded to immediately.

	trojan.exe	864	C:\Users\Lucian\Downloads\trojan.exe	ESTABLISHED	192.168.1.208	49343	192.168.1.105	4444	TCP
---	------------	-----	--------------------------------------	-------------	---------------	-------	---------------	------	-----

	Download Type	Source URL	Target Directory	File Name	File Size	Bytes Downloaded	State	Start Date	End Date	Last Accessed
	Manual	https://192.168.1.105:8000/trojan	C:\Users\Lucian\Downloads	trojan	7 Kilobytes	7 Kilobytes	Finished	2023-06-17 16:37:48Z	2023-06-17 16:37:49Z	

- b. Could you identify the origin of the file communicating with this machine? (5p)

It is an executable located in the **Downloads** folder. This indicates the file was downloaded and then executed.

The source URL is **192.168.1.105:8000/trojan**.

Download Type	Source URL	Target Directory	File Name	File Size	Bytes Downloaded	State	Start Date	End Date	Last Access
Manual	http://192.168.1.105:8000/trojan	C:\Users\Lucian\Downloads	trojan	7 Kilobytes	7 Kilobytes	Finished	2023-06-17 16:37:48Z	2023-06-17 16:37:49Z	

- c) There is a connection from qModMaster to another machine. Identify:

- a. The process name and ID (2.5p)

Answer : qModMaster.exe / PID : 3880

qModMaster.exe	3880	C:\Users\Lucian\Desktop\qModMaster	ESTABLISHED	192.168.1.208	49588	192.168.1.44	1502	TCP
----------------	------	------------------------------------	-------------	---------------	-------	--------------	------	-----

- b. The launch date (5p)

Answer : 2023-06-17

URL	file:///C:/Users/Lucian/Desktop/qModMaster-Win32-...	0	2023-06-17 16:42:12Z
-----	--	---	----------------------

- c. The destination IP and port (2.5p)

Answer : IP is 192.168.1.44 / Port destination is 1502

qModMaster.exe	3880	C:\Users\Lucian\Desktop\qModMaster	ESTABLISHED	192.168.1.208	49588	192.168.1.44	1502	TCP
----------------	------	------------------------------------	-------------	---------------	-------	--------------	------	-----